Introduction to Cybersecurity

Dr. Muhammed Abdel Hameed

Faculty of Computers & Information

Computer Science Dept.

Lecture 6

Lecture Rules

Cyberattacks and Vulnerabilities Part II

Lecture Outline

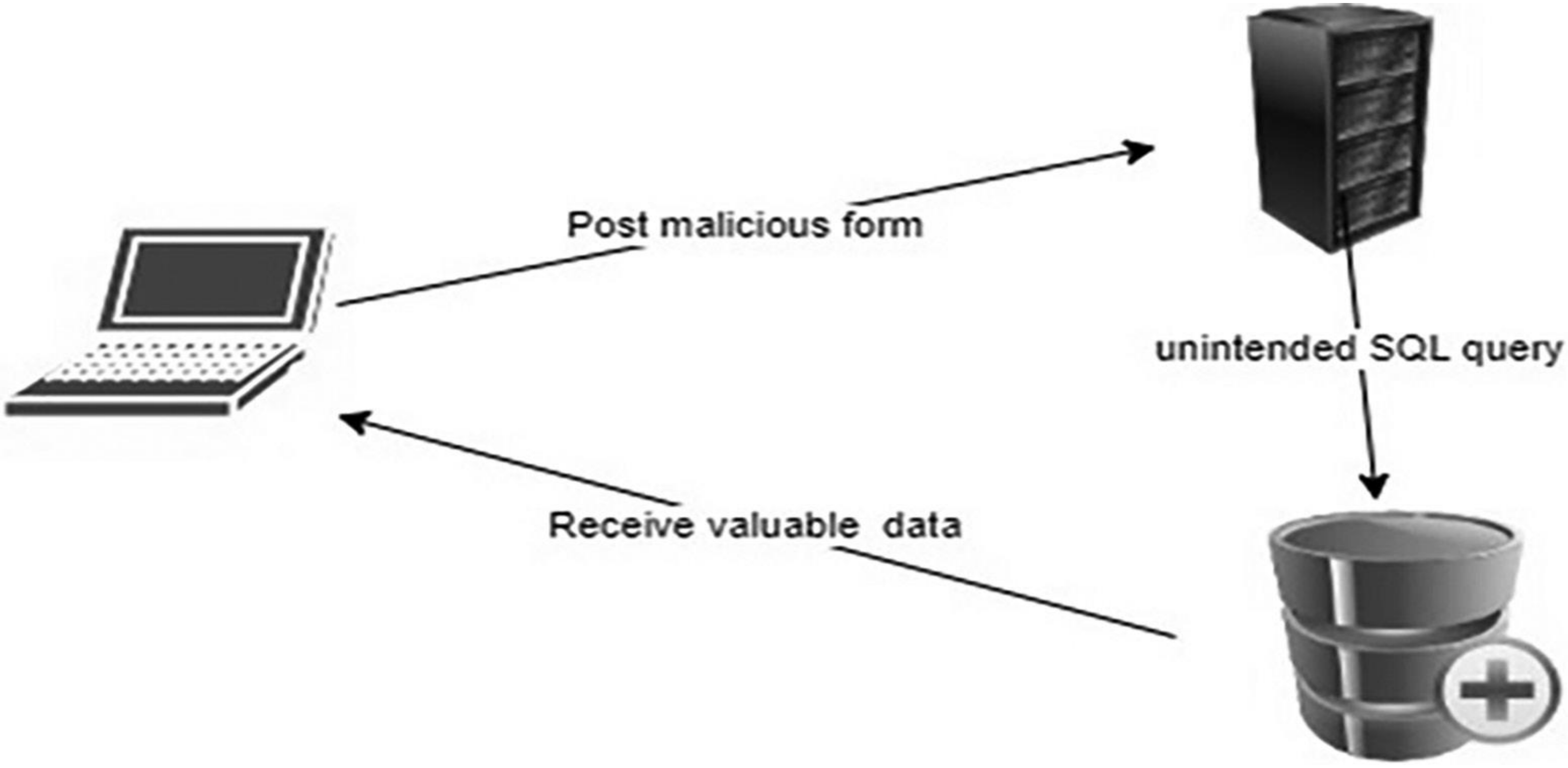
- **SQL Injection Attack**
- **Spamming**
- **Zero-Day Exploitation**
- **Phishing**
  - **Phishing Vs. Spoofing**
  - **Phishing Vs. Spamming**
- **Cyber Frauds and Forgery**

SQL Injection

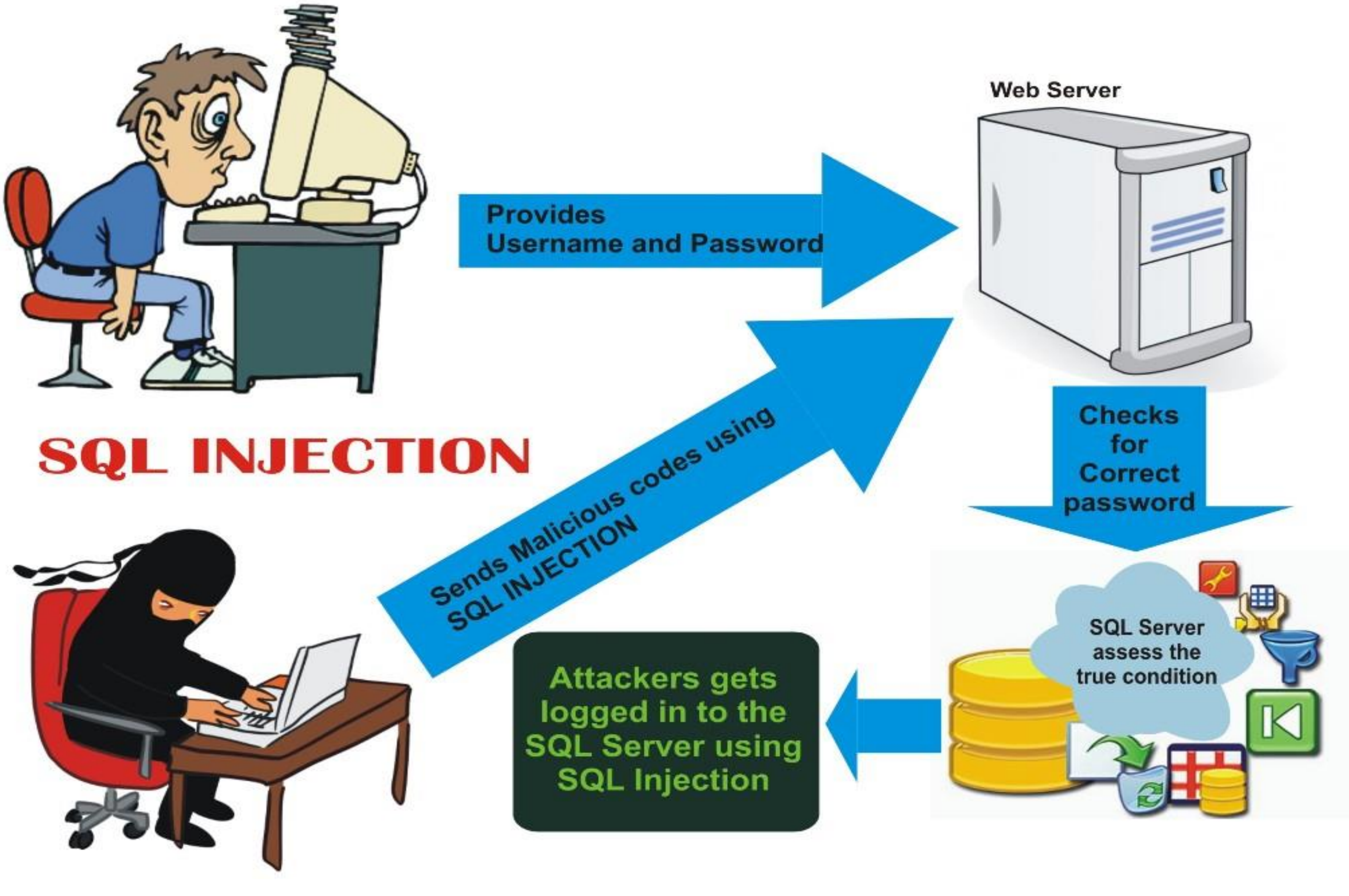
- A type of **malicious practice** to **steal** the **valuable data** from the **database server**.
- This method **exploits** the **vulnerabilities** in the **traditional Active Server Page** (ASP) **websites**, **PHP applications**, and **SQL server** forms.
- The **malicious** user **appends** an **SQL** command in the **back-end** of the **SQL** form field.
- The **objective** of that command is to **break** the **original** SQL **script** and run the **malicious** script **attached** with the **SQL form**.

SQL Injection

- **IT**, **banks** and **e-transaction website**, and **government** websites were the **top three fields** badly **affected** by the web application attacks that **predefined** by **SQL injection** attacks.



SQL Injection



Spamming

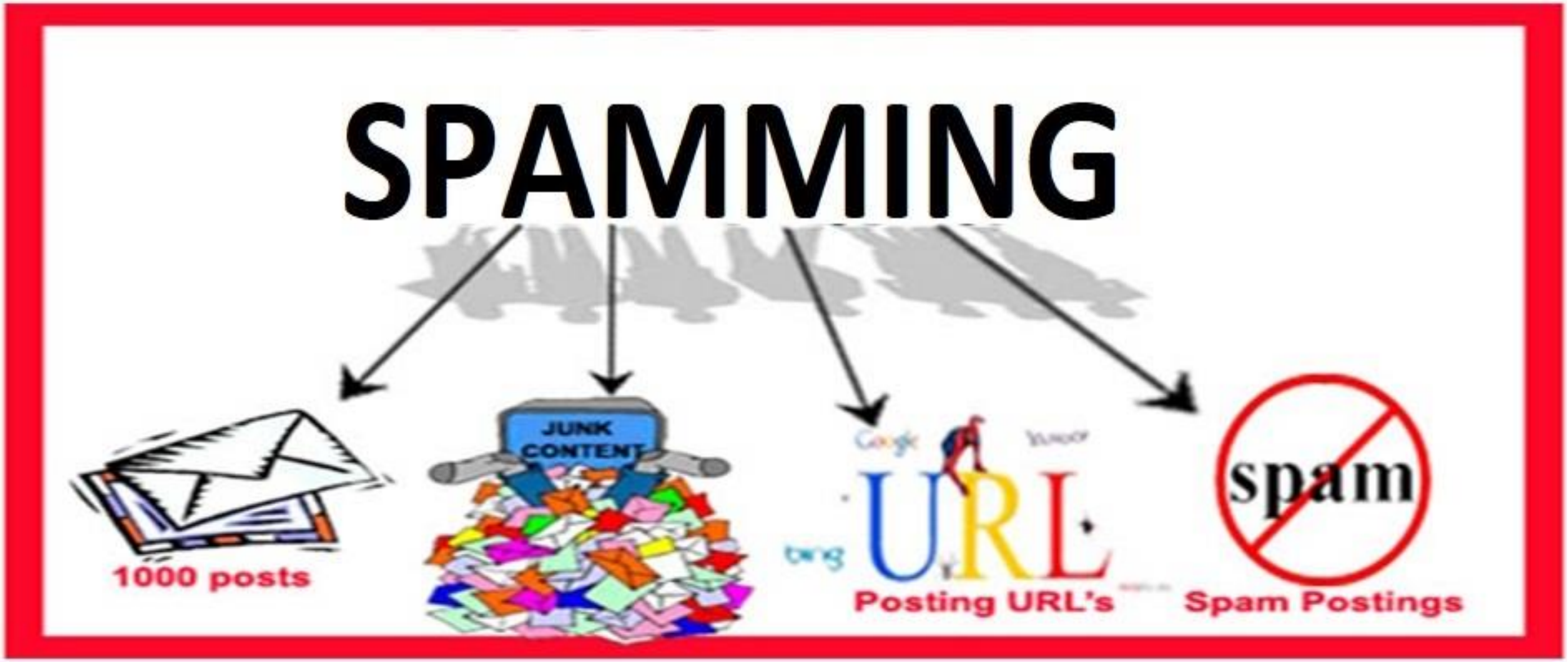
- **Spamming** in the IT **field** is the name of **sending junk mails** and **messages** to the **users** in **bulk without** getting **consent** from the **users**.
- The **hackers** also use **spamming** for **spreading malware**, **viruses**, **phishing**, **Trojans**, **worms**, and **spyware**.
- **Spamming** is a **widespread** form of **malicious attacks** used to send the **unauthorized messages** through **different** modes of **messaging** such as instant **messages**, **emails**, **social network** messages, **ads**, **mobile** phone **messages**, and **social groups**.

Spamming

- According to the **research**, more than **14.5 billion emails** were **sent** out on the **Internet** daily basis in the **starting months** of **2018** .

- The **senders** of **spam emails** all around the **world collectively earn** about **US $7,000 per** day.

Spamming



SPAMMING TOOLS

Zero-Day Exploitation

- It is a **vulnerability** in the **computer software system** that is **known** exactly on the **same day** when the **malicious attacks** exploit that **vulnerability**.

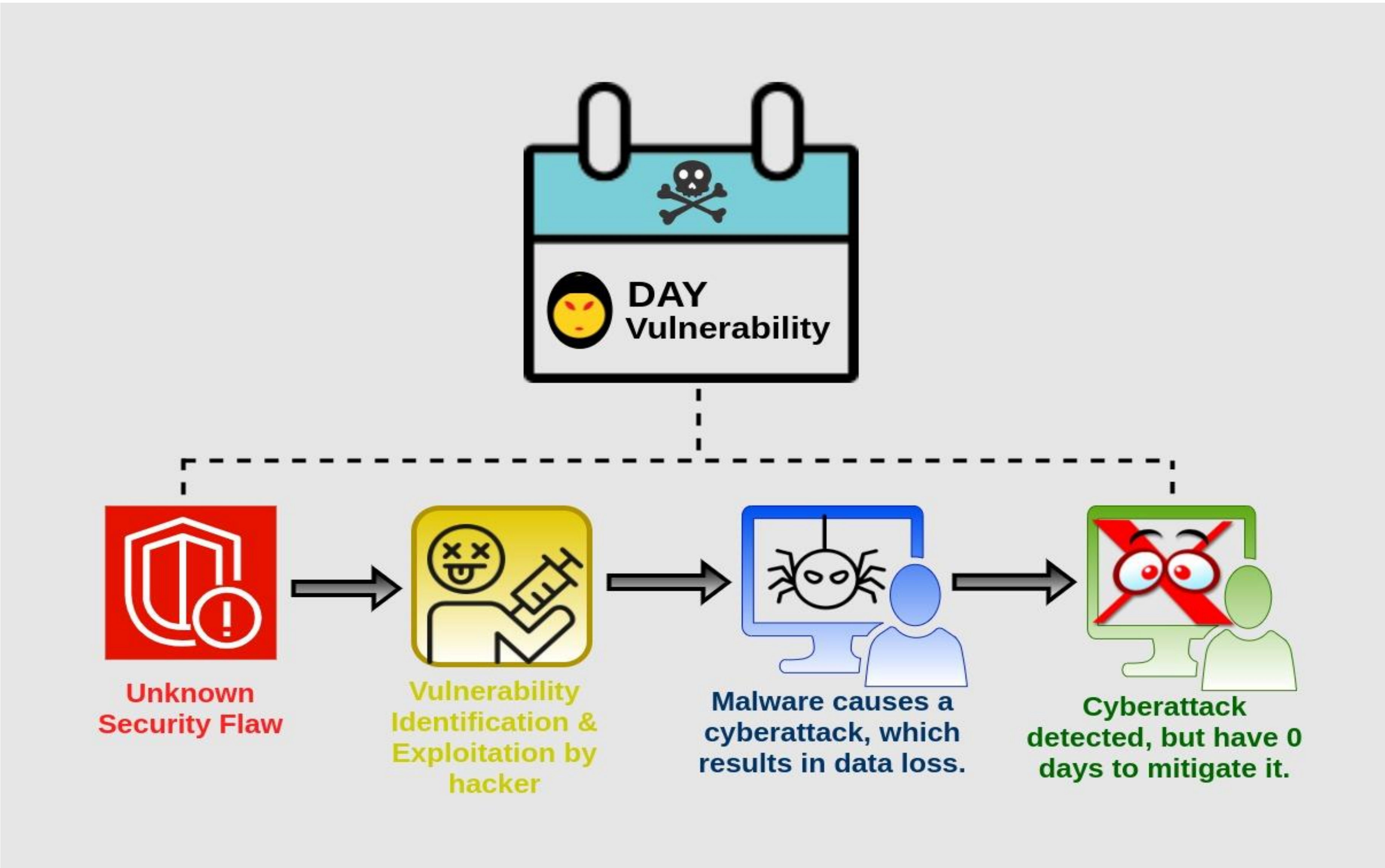
- In this attack, there is **almost no time** to patch up (correct) the **vulnerability** of the **software** because it was known at the **same time** when the **attack occurred** and **no time** was **available** for the **software engineers** to **tackle this issue.**

- **Google** has paid over **US$3 million** in the **name** of bug bounty rewards in **2017**.

Zero-Day Exploitation

- **Either** to **prevent** or to **reduce** the **impact** of the **zero-day vulnerabilities**, many **companies** run incentivized programs for the hackers to find out the **zero-day vulnerability** against the **pre-announced** bounty commonly referred to as **bug** bounty **rewards**.

Life cycle of a zero day



Phishing

- It is a type of **cyberattack** in which the **targeted person** is **flooded** with **emails** similar to those from their **banks**, **insurance companies**, and **other service providers**.

- The hacker **targets** people through **emails** to get their **sensitive** and **personal information** related to **their financial** and **other** account **information**.

Phishing

- The main target of the **phishing** attack is to get the **information** about the **credit card number**, **ATM pin codes**, **passwords**, **user name**, and the **related information**.
- Once the **information** has been **collected**, the **hackers** use that **information** to **steal** the **money** or other **valuable digital** assets.
- This **attack** is **normally** used for the **financial theft** of the **bank accounts**.

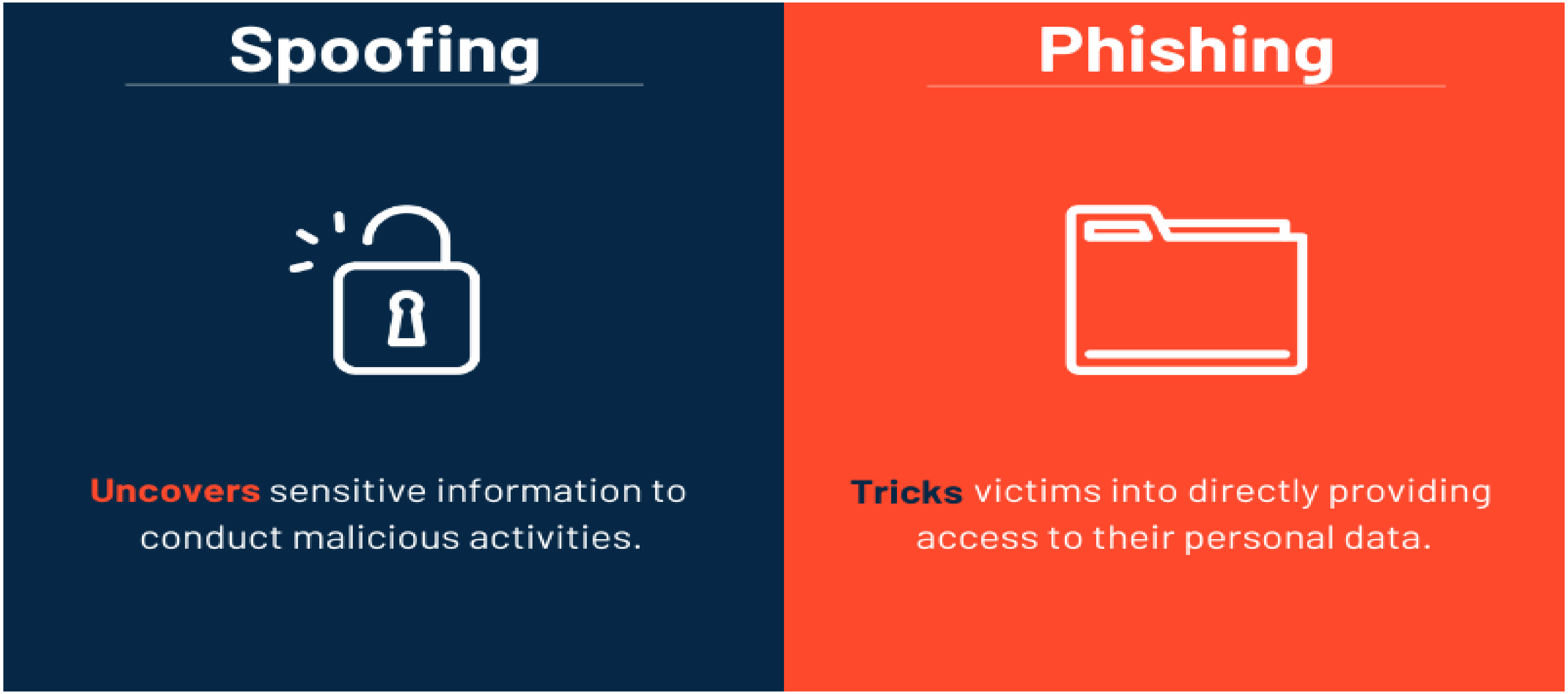
Phishing

- There are **three major modes** of phishing used in the **modern phishing** activities as listed below:

    - **Telephone calls** commonly referred to as **voice phishing**, or vishing.
    - **Emails** referred to as **general phishing**.
    - **Small** text **messages** (SMS) referred to as **smishing**.

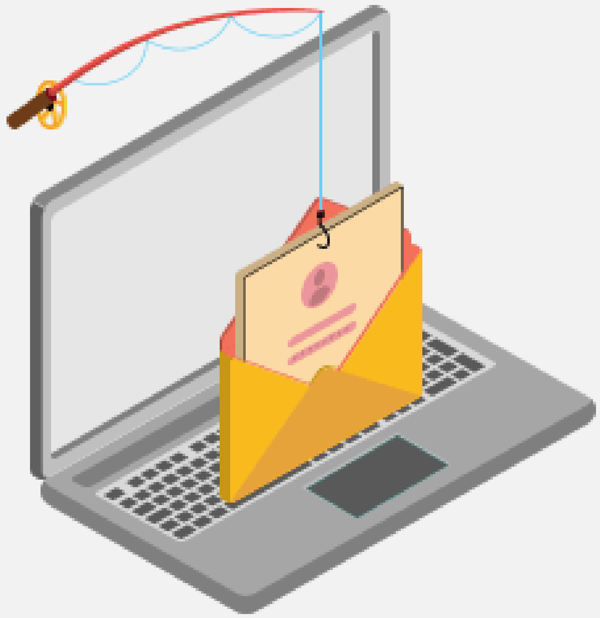
Phishing

Spoofing Vs. Phishing



- In **Spoofing**, a **hacker tries** to **grab** the original identity of a genuine user, while in **Phishing**, **hackers** design a **plot** to **reveal** some **sensitive data** about the **user.**

Spamming Vs. Phishing



PHISHING

Phishing attacks are designed to steal user private information such as passwords, bank accounts, credit card details, etc.

SPAM

Spam is unsolicited email or junk having irrelevant content or commercial advertising contents.

Cyber Frauds and Forgery

- It is a **new** form of **cyberattack** in the **modern digital world**. In this form of **crime**, the **digitally** stored **documents** are **forged** to form the **Fake** (**counterfeit)** **documents**.
- This **crime** is **increased** during the **recent years** due to the **availability** of **high-tech** devices like **computer software**, **printers**, **scanners**, **cameras**, **mobiles** and **other tools.**

How defend from cyber fraud and forgery?

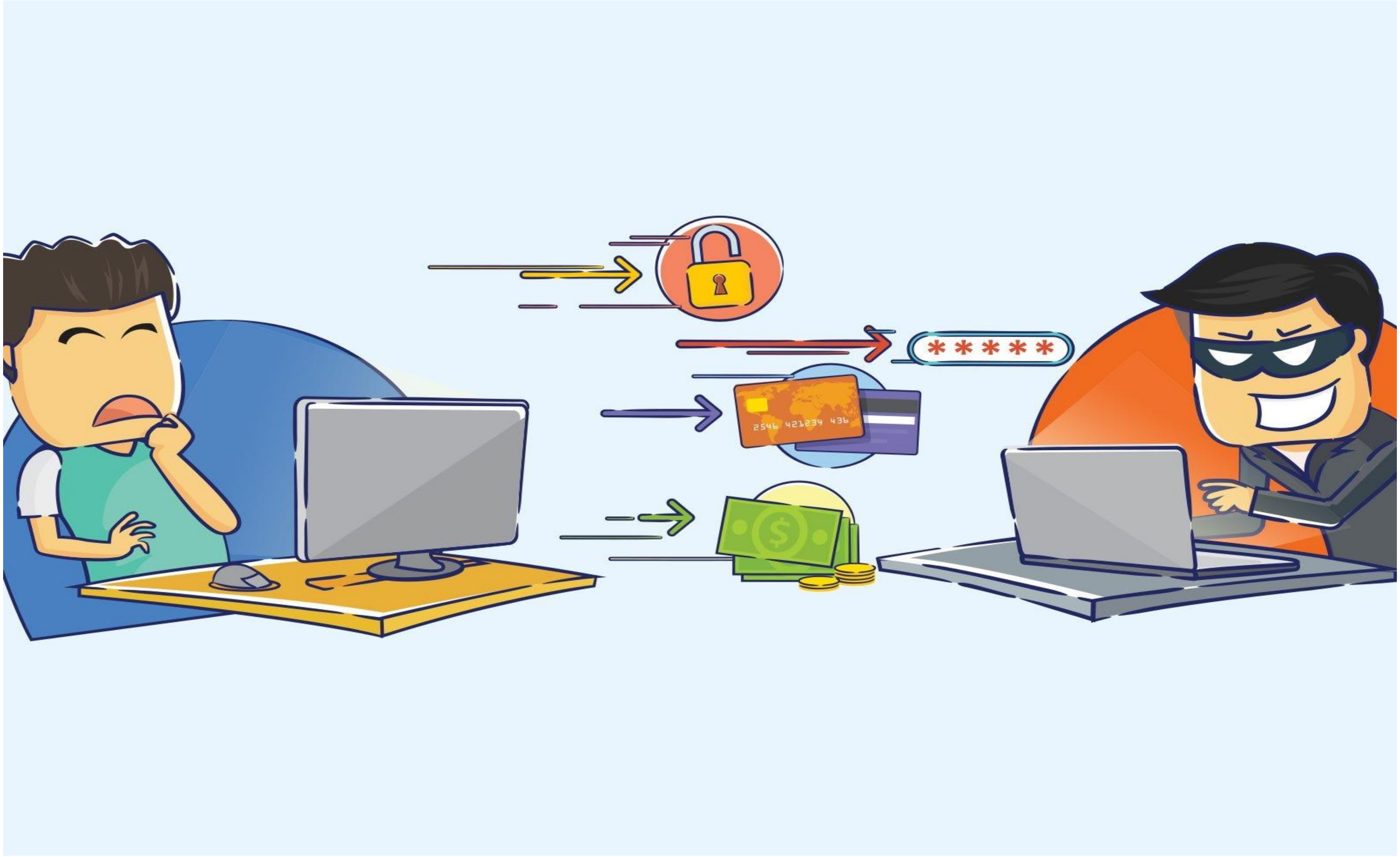
- **Here are some simple steps to protect you from fraud:**
  - Do not give any **personal information** (name, address, bank details, email or **phone number**) to **organizations** or **people** before **verifying** their **credentials**.
  - **Many frauds** start with an **email**. **Remember** that **banks** and **financial institutions** will not send you an **email asking** you to **click on** a **link** and **confirm** your **bank details**.

How defend from cyber fraud and forgery?

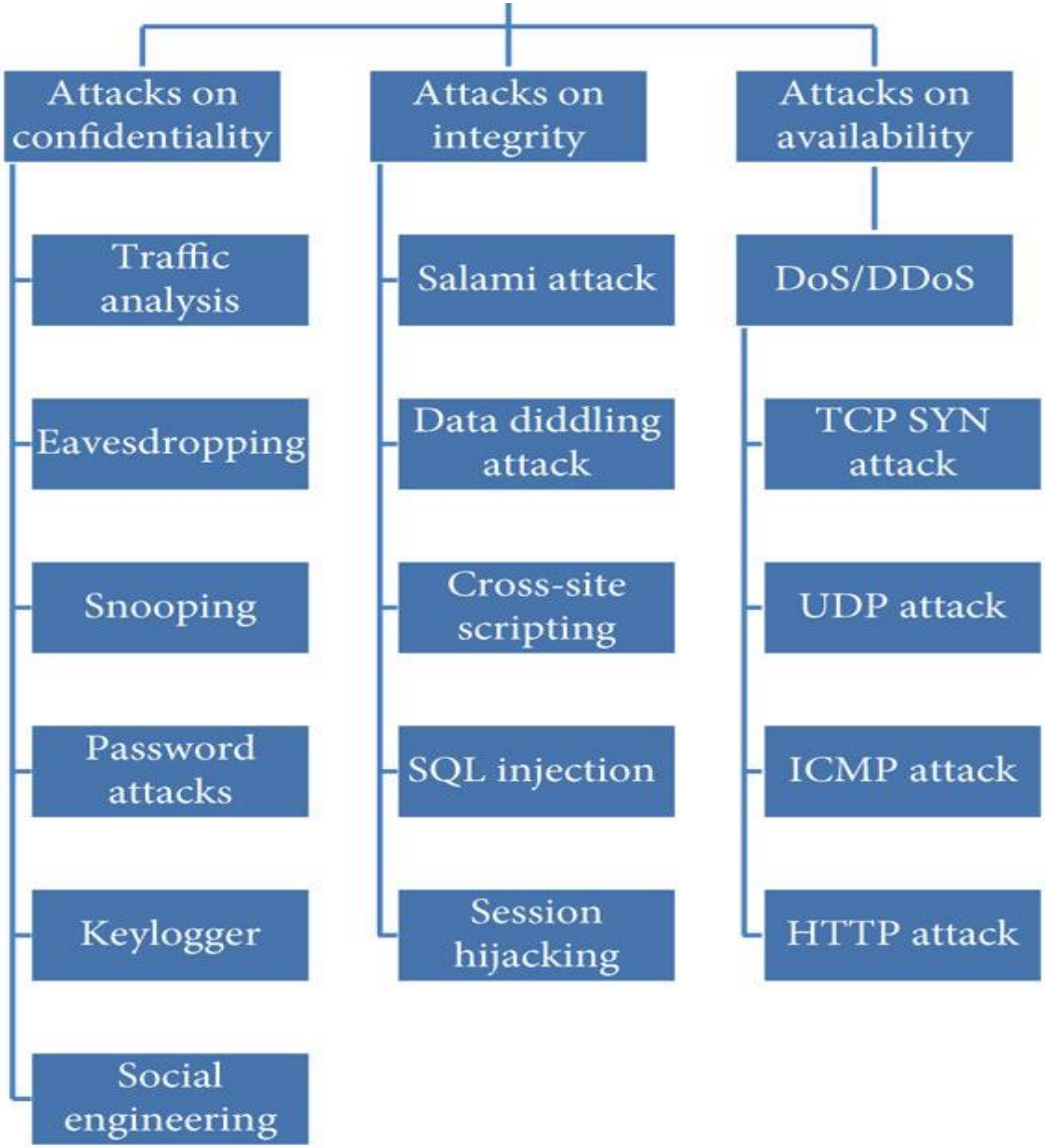
- **Destroy** and **preferably** shared **receipts** with your **card details** on and **post** with your **name** and **address** on.

- If you have been a **victim** of **fraud**, be **aware** of **recovery fraud**. This is when **fraudsters** pretend to be a **lawyer** or a **law enforcement officer** and tell you they can help you **recover** the **money you've already lost**.

Cyber Frauds and Forgery



Cyberattacks Mind map



Questions & Answers

Q1.What is DoS Attack? What are the general symptoms?

A1: Denial of service or DoS is an Internet security-related event in which the hackers attack a particular server running some Internet services to prevent it from working normal or to stop the services. In this case, the servers are overwhelmed with the flooding of superfluous messages.

The major symptoms of being the victim of DoS attacks (for a legitimate user) include the following:

- Inability in accessing a website.
- Delay in accessing online service.
- Huge delays in file opening on the websites.
- Increased volume of spam emails.
- Degradation of performance of service.

Questions & Answers

Q2. What is MITM?

A2: In the "Man-in-the-Middle" or **MITM cyberattack**, the hacker intercepts the normal connection between the user and the web server without any knowledge of both user and server. The legitimate communication link between the two entities is exploited, intercepted, and decrypted to steal the personal information for malicious use.

Task 1 (10 Min)

- **Use the substitution table to encrypt the following plaintexts:**

1- We Leave at 14 March 2024.

2- Go to airport at 17.25 am.

a	b	c	d	e	f	g	h	i	j	k	l	m
X	N	Y	A	H	P	O	G	Z	Q	W	B	T

n	o	p	q	r	s	t	u	v	w	x	y	z
S	F	L	R	C	V	M	U	E	K	J	D	I

0	1	2	3	4	5	6	7	8	9	.
3	5	6	7	2	9	1	0	4	8	.

Task 2 (10 Min)

- Find the **plaintext** by using the **Rail Fence** cipher to **decrypt** the **following:**

- **ciphertext: WSLDHTHUDEOAOWX** **Key: 3**

thanks for listening!